

TRYHACKME CASE STUDY REPORT

Raghavi Preeti Ayyathurai Jaya

March 09, 2026

Table of Contents

1	Case Study 01 - Tempest	1
1.1	Executive Summary	1
1.2	Incident Overview	1
1.3	Technical Findings	1
1.4	Recommendations for Better Security	2
2	Case Study 02 - Boogeyman 1: Initial Access & Exfiltration	2
2.1	Executive Summary	2
2.2	Incident Overview	2
2.3	Technical Findings	3
2.4	Recommendations for Better Security	3
3	Case Study 03 - Boogeyman 2: Persistence & Privilege Escalation	4
3.1	Executive Summary	4
3.2	Incident Overview	4
3.3	Technical Findings	4
3.4	Recommendations for Better Security	4
4	Case Study 04 - Boogeyman 3: Enterprise Wide Compromise	5
4.1	Executive Summary	5
4.2	Incident Overview	5
4.3	Technical Findings	5
4.4	Recommendations for Better Security	6

1 Case Study 01 - Tempest

1.1 Executive Summary

A critical intrusion was detected on the workstation **TEMPEST (User: benimaru)**. The attack originated from a malicious document that exploited a remote code execution vulnerability to gain initial access. The attacker successfully escalated privileges to **NT AUTHORITY\SYSTEM**, performed internal reconnaissance, and established persistent administrative access through a reverse socks proxy and a custom Windows service.

1.2 Incident Overview

The intrusion began when the user downloaded **free_magicules.doc** via **chrome.exe**. This document utilized **CVE-2022-30190 (Follina)** to trigger a chain of commands through Microsoft Word (WinWord.exe, PID 496). The attack progressed through two stages of payload execution, leading to credential harvesting and the creation of unauthorized administrative accounts.

1.3 Technical Findings

- **Initial Vector:** Malicious document free_magicules.doc utilizing the Follina exploit.
- **Infrastructure & C2:**
 - Stage 1 Payload URL: <http://phishteam.xyz/02dcf7/index.html>
 - Stage 2 Domain/C2: resolvecyber.xyz (Port 80).
- **Reverse Proxy:** Attacker used **chisel** (ch.exe) to establish a reverse socks proxy on port 8080.
- **Malicious Artifacts:**
 - PowerShell Payload: A base64 encoded command was used to download the stage 2 binary via certutil.
 - Persistence Binary: final.exe (located in C:\ProgramData\).
 - Privilege Escalation Tool: spf.exe (PrintSpoofer) was used to exploit SeImpersonatePrivilege.
- **Post-Exploitation Activity:**
 - Sensitive Data: Attacker discovered a password (infernotempest) in a local file.
 - Unauthorized Accounts: Two users, shion and shuna, were created (Event ID 4720).
 - Administrative Access: User shion was added to the local administrators group (Event ID 4732).

Service Persistence: A Windows service named TempestUpdate2 was created to run final.exe automatically on boot.

1.4 Recommendations for Better Security

- Ensure all systems are patched against CVE-2022-30190 and similar MS Office-related RCE vulnerabilities.
- Restrict SeImpersonatePrivilege to only necessary administrative service accounts to prevent PrintSpoofer-style escalations.
- Disable macros and implement Attack Surface Reduction (ASR) rules to block Office applications from creating child processes.
- Implement DNS filtering to block known malicious domains like phishteam.xyz and resolvecyber.xyz.
- Monitor for unusual outbound traffic on non-standard ports that could indicate proxying or tunneling tools like Chisel.
- Enable enhanced auditing for Event ID 4720 and 4732 to trigger immediate alerts whenever new users are created or added to sensitive groups.

2 Case Study 02 - Boogeyman 1: Initial Access & Exfiltration

2.1 Executive Summary

A phishing attack successfully targeted a finance employee at **Quick Logistics LLC**. The threat actor impersonated a business partner regarding an unpaid invoice, delivering a malicious attachment that initiated an execution chain. The attacker utilized living-off-the-land techniques to enumerate the endpoint, locate sensitive data, and exfiltrate a password database via specialized protocol tunneling.

2.2 Incident Overview

The intrusion targeted a specific victim endpoint assigned to **Julianne Westcott (julianne.westcott@hotmail.com)** within the Finance Department. The initial delivery vector was an inbound phishing email originating from a lookalike domain spoofing **B Packaging Inc. (agriffin@bpakcaging.xyz)**. The attack successfully executed when the user interacted with a malicious shortcut payload disguised as an invoice.

2.3 Technical Findings

- **Initial Vector:** Malicious shortcut (.lnk) file masquerading as a legitimate billing document.
- **Execution Chain:** Opening the .lnk file triggered an obfuscated **PowerShell** script block payload to initiate external connections.
- **Infrastructure & C2:** Malicious external file hosting and Command and Control (C2) domains were utilized to host secondary stages and receive system data.
- **Post-Exploitation Enumeration:** Attacker downloaded and executed a renamed version of **Seatbelt** (sq3.exe) to perform local situational awareness, host auditing, and security control profiling.
- **Malicious Artifacts:** Unauthorized extraction and access of a sensitive KeePass password database (.kdbx) file located on the filesystem.
- **Data Exfiltration Technique:** The attacker base64/hex encoded the .kdbx file, split it into chunks, and exfiltrated the sensitive data completely via outbound **DNS A queries** to an authoritative subdomain.

2.4 Recommendations for Better Security

- Implement email authentication protocols (SPF, DKIM, DMARC) to block spoofed or lookalike domain delivery attempts.
- Restrict or disable user execution of shortcut (.lnk) files originating from external or untrusted email attachments.
- Deploy continuous endpoint monitoring to detect anomalous administrative living-off-the-land binaries like Seatbelt or renamed compliance tools.
- Implement strict DNS logging and behavioral analysis to flag high-frequency or structured sub-domain queries indicative of DNS tunneling.
- Enforce localized application white-listing or explicit blocklists for unauthorized outbound communication over raw DNS streams.

3 Case Study 03 - Boogeyman 2: Persistence & Privilege Escalation

3.1 Executive Summary

Following the initial foothold, the threat actor shifted operations toward securing long-term operational persistence and elevated rights within **Quick Logistics LLC**. By deploying a targeted spear-phishing email utilizing an upgraded delivery channel, the attacker leveraged malicious document macros to run secondary payloads. Active footprinting was successfully maintained on the endpoint via native scheduling frameworks.

3.2 Incident Overview

The threat actor adjusted delivery vectors to bypass corporate spam filters by utilizing a third-party mail relay platform, **Elastic Email**. The payload arrived as a weaponized Microsoft Word document embedded with highly obfuscated **VBA macros**. Once execution rights were granted by the user, the attack chain established secondary beaconing and persistent administrative tasks.

3.3 Technical Findings

- **Initial Vector:** Weaponized Microsoft Word document utilizing heavily obfuscated macro content.
- **Infrastructure & Payload Delivery:** Enabling macros forced the execution of VBA routines that connected to an external C2 infrastructure to pull down a compiled executable binary payload.
- **Persistence Mechanism:** Attacker configured an unauthorized Windows **Scheduled Task** pointing to the dropped binary, ensuring automated code execution during workstation reboots.

3.4 Recommendations for Better Security

- Enforce strict Group Policy Objects (GPO) to completely disable VBA macros in Office documents received from external or internet-zone sources.
- Configure mail gateways to inspect, flag, or quarantine inbound correspondence routed through generic third-party bulk email services like Elastic Email.
- Monitor for anomalous parent-child process relationships, specifically targeting cases where Microsoft Word ('winword.exe') spawns command shells or web utilities.

- Implement continuous audit monitoring on Scheduled Task creation events (Windows Security Event ID 4698) to flag unauthorized execution paths.
- Audit and restrict local directory write permissions to block non-administrative profiles from executing binaries out of common user profiles or temporary areas.

4 Case Study 04 - Boogeyman 3: Enterprise Wide Compromise

4.1 Executive Summary

The intrusion escalated into a full enterprise-wide compromise of the **Quick Logistics LLC** internal Active Directory domain. Utilizing credentials harvested during earlier phases of the lifecycle, the threat actor migrated laterally across infrastructure segments, bypassed advanced endpoint defenses, and executed credential dumping routines. The attack culminated in the unauthorized modification of domain controller objects and full-scale administrative dominance.

4.2 Incident Overview

The threat actor shifted focus from individual target workstations to core infrastructure assets. The campaign progressed from an isolated network foothold to deep lateral movement across server infrastructure using compromised internal service accounts. Advanced evasive maneuvers, including memory-space manipulation and living-off-the-land orchestration, were documented across security logs during the domain takeover.

4.3 Technical Findings

- **Lateral Movement Vector:** Execution of unauthorized remote commands via native administration frameworks, utilizing **WinRM** and **WMI** to pivot between host segments.
- **Evasion & Process Manipulation:** Threat actor utilized advanced living-off-the-land binaries and API-level hooking to blind local telemetry collection and bypass endpoint detection rules.
- **Credential Harvesting:** Successful extraction of memory-resident secrets via LSASS memory dumping using a customized **Mimikatz** implementation and specialized parsing tools.
- **Infrastructure Takeover:** Implementation of a **Golden Ticket** or **DCShadow** attack vector, injecting malicious domain objects directly into Active Directory replication cycles to sustain domain-wide

control.

- **Malicious Artifacts:** Unauthorized administrative session tokens and temporary staging profiles created on primary corporate Domain Controllers.

4.4 Recommendations for Better Security

- Enforce a rigid tier-based administrative model to restrict domain administrator credentials from interacting with lower-security workstations or member servers.
- Implement explicit network isolation and access control lists (ACLs) to block lateral WinRM, WMI, and RPC traffic between standard user subnets.
- Enable enhanced protections for the Local Security Authority (LSA) process by enforcing LSA Protection (RunAsPPL) to prevent unauthorized credential dumping.
- Continuously audit and alert on unusual Active Directory replication behavior, specifically tracking event patterns associated with unauthorized domain sync requests or replication source modifications.
- Implement comprehensive behavior-based detection rules within the SIEM to flag sudden, high-volume directory service queries originating from non-standard systems.